

Exporter Onboarding & Compliance

Implementation Plan and Decision Record

This document is the single reference for the exporter onboarding and compliance work. It records what the system does today, what is broken, what exists but was never connected, what has to be built, the order the work happens in, and — most importantly — every decision taken and the reason it was taken.

Every claim about the current state was verified against the code. File paths and line numbers are given so nothing has to be taken on trust. Where two existing documents disagree, this one says which the code supports.

Version	1.1
Status	Decisions locked · ready to build
Changed in 1.1	D5 and D10 — approval is now a single approver , not two. D8 — the cloud target is AWS S3, not GCP. New D14–D17 cover document categories and evidence snapshots.
Scope	Exporter CRM layer (Path B). The formal Temporal orchestration path is formally out of scope — see D11.
Supersedes	README gap list · cases/README · blueprint status rows · the implementation guide's RXIL enum claim

0 How to use this document

Read sections 1 to 4 once, in order. They establish what the system is, what state it is in, and what we decided to build. After that the document is a reference: go straight to the register you need.

Section	Use it when
1 – 2 Context and current state	Starting on the project, or unsure whether something already exists
3 Decisions	About to question why something is built a particular way. Answer it here before reopening it
4 Target flow	You need to know where a piece of work sits in the product
5 – 7 Fix / Wire / Build registers	Picking up a task. Each item has its evidence and its acceptance test
8 Build order	Planning a sprint, or about to start something out of sequence
9 Go-live gates	Before anything external touches the system
10 Ticket impact	Updating Jira
11 Open questions	Blocked and wondering whether it is known

Three conventions used throughout.

- **FIX** — code that runs today but is broken, unsafe, or loses data.
- **WIRE** — code that is finished and tested but has no caller. Connecting it is glue, not new logic.
- **BUILD** — the code does not exist. Build the smallest honest version behind an interface, so the production version is a swap.

Item references (A1.1, B4, C2 and so on) are stable. Use them in commit messages and pull requests.

1 Context

1.1 What this system is

An internal CRM for exporters, plus a verification and compliance record. An operator creates an exporter, records contacts and activities, moves them through a pipeline, runs verification checks, and records compliance review. The exporter never logs in; everything is operator-driven.

Two sources of exporters. **RXIL** partners with us and supplies pre-filtered exporters along with their own KYC, AML/CFT, invoice duplication, vessel tracking, e-bill of lading, buyer rating and insurance results — which we ingest and never recompute. **External exporters** come to us directly with no prior verification, so we run it ourselves.

1.2 Two pipelines exist. We build on one.

The codebase contains two unrelated onboarding implementations, and this has been the single largest source of confusion.

	Path A – formal orchestration	Path B – Exporter CRM
What it is	onboarding_request, a Temporal workflow, an 18-state machine. What the Jira 4.1 epic describes.	exporter_profile, the generalized verification_result table, the screening checklist. Built for the RXIL product need.
Does it run?	No. The Temporal worker was removed from bootstrap.py:334–349; TEMPORAL_ENABLED defaults False; enabling it is unsupported in this checkout.	Yes. Real HTTP API, real frontend, used end to end today.
Verdict	Formally out of scope (D11).	This is the onboarding flow. All work happens here.

The exporter's lifecycle_status is the single source of truth for where a relationship stands. onboarding_request remains, but only as a thin per-attempt record — one row per verification pass, including redos. It is not a second state machine.

1.3 The wiring rule

A great deal of finished code was built for other parts of the platform and never connected to anything. We connect it rather than rebuild it, under one standing rule:

All glue code lives in the **onboarding** module. No file in kyb, cases, customers or compliance is edited. Consequently: onboarding may import other modules; nothing may import onboarding.

This matters for three reasons. Each of those modules was delivered against a Jira ticket whose acceptance criteria still hold if we do not touch it. The coupling sits in one place and can be removed in one place. And when a module's own API eventually arrives, it calls its services directly and our adapters are deleted, not untangled.

2 Current state, verified

Everything below was checked against the code. Two earlier documents described this system inaccurately in both directions — one understated what exists, one overstated it. This is what is actually there.

2.1 Works end to end today

Capability	Notes
Login, refresh, logout	Password and JWT, backed by User and RefreshToken
Create exporter (lead)	Creates an exporter_profile and a minimal onboarding_request. Requires an Idempotency-Key header
Exporter list and search	Filter by GSTIN, PAN, IEC, legal name, source, status
Exporter detail page	Profile, contacts, recent activities, onboarding history
Contacts and activities	Single primary contact; activities are append-only, enforced by database trigger
Lifecycle transitions	10 states, 13 permitted edges, enforced server-side. Kanban allows only legal drags
Verification records	Manual provider. Create, list, and a one-time immutable review
Screening checklist	Eight items per exporter. Editable — but see A2.1

2.2 Built, tested, and reachable by nothing

This is the largest untapped asset in the codebase. None of the following is called by any production code path.

Asset	State	Ref
kyb module — Middesk (US), Trulioo (international), ports, registry	Imported by no production code. The only real import is in tests/contract/test_kyb_interface.py:6	B4
ConfigDrivenRiskRater	Tested, never called. No result is stored against an exporter	B3
OnboardingQueryService — evidence package, statistics, time-in-state	Complete and tested. Hangs off no router	B1
cases module — lifecycle, notes, resolution, evidence aggregation, SLA. A two-person rule exists as a configuration flag, left off per D5	Nine application modules. No router. Nothing creates a case outside tests	B7
document_requirements_service	Built, service-only, not reachable over HTTP	B2
Sumsub identity adapter and webhook	Real, but SUMSUB_ENABLED=false and only on the legacy path	B5
EventBus, build_envelope, OnboardingEventPublisher	Working, in-memory. No CRM service uses it	B6
onboarding_event table	Append-only and trigger-enforced. No route reads it	A2.3

2.3 Does not exist in any form

Missing	Evidence	Ref
Document storage	app/platform/storage/ is eleven zero-byte files. VerificationResult.evidence_reference and OnboardingDocument.storage_path are pointers into nothing	C1

Missing	Evidence	Ref
File upload or download	No UploadFile or multipart handling anywhere	C1
Malware scanning	No step, no vendor	C2
AML / sanctions screening for an entity	The compliance mock engine is keyed to payments.transactions — the wrong shape for an exporter	C6
Invoice and Buyer records	No model. VerificationType.INVOICE and VerificationEntityType.INVOICE exist but point at a table that does not	C8, C9
RXIL ingestion	StubRxilAdapter only. No endpoint. Real mechanism unknown	C13
Re-verify and reopen controls	Backend permits a second result; the UI never offers it	C4, C5

2.4 Baseline

There is no established test baseline. 2,692 tests collect cleanly with zero collection errors; 617 pass without a database. The rest need Postgres and have never been run to completion here. No failure observed was caused by a missing module — every one was the absent database. The frontend build fails on main at PipelinePage.tsx:56, so vite build never runs.

Establishing the real baseline is the first task in the plan (A4.1). Without it there is no way to distinguish "I broke this" from "this was already red".

3 Decisions and their reasoning

This is the section to read before questioning why something is built a particular way. Each decision records what was chosen, what was rejected, and why. If a decision needs to change later, change it here first.

#	Decision	Reasoning
D1	Role matrix as proposed. OPERATIONS and above for CRM writes; COMPLIANCE/ADMIN for reviews, checklist and audit; reads open to any authenticated user; never DEVELOPER or API_USER.	The blueprint's Relationship Manager persona adds exporters, logs activity and moves pipeline cards. A COMPLIANCE-only sweep would break screens that already work. Reads stay open because the alternative blocks the RM from their own accounts.
D2	Follow-ups stay team-wide. Everyone sees all pending work.	It is the one deliberately cross-user view in the CRM. Restricting it would make EXP-F7's acceptance criterion false and remove the only team-level visibility we have.
D3	First ADMIN via an idempotent seed command reading credentials from environment variables, run at deploy. It creates the first ADMIN and one COMPLIANCE account.	Removing self-service roles leaves no path to an admin. A seed command is explicit and repeatable across environments, unlike a check that runs silently on every boot.
D4	Providers stored lowercase (manual, rxil), displayed uppercase. No data migration.	Existing rows already say 'manual'. EXP-2's headline test and the blueprint promise that 'RXIL' displays as 'RXIL' — that is a promise about what a user sees, not about the column.
D5	Approvals go through the case engine, with a single approver. The two-person rule stays switched off. One person records a rationale and decides. Applies at both gates.	The engine is used for what it uniquely provides — a real case record, aggregated evidence, a mandatory rationale, an SLA clock and a reopenable decision — without the staffing a dual-approval rule demands. The README describes the CEO reviewing RXIL items, which reads as a single decision-maker; a two-person rule would either stall or become ceremonial. The rule is a configuration flag, so enabling it later is a switch, not a rebuild. What matters is that approval runs through the case engine rather than a lifecycle click.
D6	Cases are created by publishing to the existing in-memory event bus, not by a direct service call.	Ticket 4.3-S2T1 specifies a Kafka consumer. No Kafka exists here. A direct call would be a second creation path that has to be unpicked later; the bus has the same shape as the eventual consumer, so switching becomes configuration.
D7	Lifecycle stage history goes to onboarding_event. Epic 4.2 reads from it.	onboarding_event is in our module, already append-only and trigger-enforced, and the service already holds a repository for it. Epic 4.2's customer_status_history is a better shape but belongs to another team's in-progress module — a far harder coupling to reverse.
D8	Document storage: local disk first, then AWS S3. Both sit behind one interface. Only a relative object key is stored — never a provider URL, bucket or scheme.	AWS rather than GCP, because of corridor restrictions on GCP. S3 maps the compliance requirements cleanly: Object Lock in compliance mode covers the seven-year AML retention requirement, SSE-KMS covers encryption at rest, IAM roles replace Workload Identity. Local disk is kept as a second adapter rather than replaced — otherwise every developer and every CI run needs AWS credentials. Build the interface and local disk first, prove the flow, then add S3; doing S3 first means debugging IAM and the flow at the same time.

#	Decision	Reasoning
D9	The malware scan step is built now; a real scanner comes later. Files land PENDING_SCAN and are not viewable until cleared. A real scanner is a go-live gate.	Retrofitting the state machine later is painful; adding a scanner behind an existing gate is easy. The step existing is what matters architecturally. With D8 on AWS, GuardDuty Malware Protection for S3 scans objects on upload natively and may satisfy the gate without self-hosting ClamAV — check before committing to either.
D10	A closed decision may be reopened by one COMPLIANCE or ADMIN user, with a mandatory reason. The reopen is a new record, never an edit.	Follows D5 — reopening should not be harder than deciding. The control here is the audit trail rather than a second person: reviews are immutable by database trigger, so a reopen physically cannot overwrite the original. The mandatory reason is what makes it defensible.
D11	Temporal is formally descoped. The CRM path is the onboarding flow.	Its worker was removed, its flag defaults off, and enabling it is unsupported in this checkout. Seven Jira tickets assume it runs. Leaving it ambiguous guarantees someone eventually builds against it by mistake.
D12	Funding is decided per invoice , not per exporter. The company gate comes first, then each invoice separately.	This reverses a deferral: the blueprint, the frontend ticket doc and the README all deferred an Invoice entity until underwriting. It is now in scope. Duplication checking in particular is impossible without an invoice history to compare against.
D13	An invoice may arrive from an operator, from RXIL, or from the exporter. The source is recorded on the invoice.	The same provenance discipline already applied to verification results. It also allows storage paths and IAM policy to be scoped by source later.
D14	Documents are grouped into ten categories, shown contextually — the exporter page shows the company categories, the invoice page shows the invoice ones. Listed in section 4.3.	Category alone does not say which gate a document belongs to: BANKING covers both company statements and per-invoice FIRCs. A single flat Documents menu would mix the two, which is exactly the confusion categorisation is meant to prevent. Showing categories in context also keeps any one view short without reducing the total available.
D15	Category is an enum; document_type within a category is seeded configuration , not an enum.	The category list is short and structural, so each addition deserves a migration. The type list will churn as new paperwork appears, and requiring a migration and a deploy for each would guarantee people work around it. This codebase already seeds config this way for document requirements and for SLA rules.
D16	Generated documents live in the same store , with source = SYSTEM, auto-passing the scan gate, recording the model and prompt version used.	One place to look is worth more than a clean separation. But a generated report has no uploader and no file a user chose, so it needs its own source value; and if it informs a funding decision we must be able to say later which version produced it.
D17	A case snapshots its evidence at proposal time — the specific document_id list, not a live folder. Documents added afterwards appear, but flagged as later additions.	Without this, a document can be uploaded or replaced between proposal and decision, and the decision silently rests on different evidence than the proposal did. Same class of defect as A2.1, where the checklist silently overwrote prior decisions. Small to build into C11, unpleasant to retrofit.

Consequences worth stating plainly

- **The case engine is still wired, and that is the point of D5.** Dropping to a single approver removes a staffing constraint; it does not return the decision to a lifecycle click. Every approval still produces a case with aggregated evidence, a recorded rationale, an SLA clock and a reopenable record.
- **D12 enlarges the build.** An Invoice entity, a Buyer, a second case type, and invoice-level checks were in no earlier plan. They are section 7's C8 to C13.

- **FINANCING_ELIGIBLE changes meaning.** It no longer means "approved for funding". It means "cleared to submit invoices". The funding decision sits below it, per invoice.
- **Three documents now contradict the build** and must be corrected in Stage 1: the blueprint, the frontend ticket doc and the README all state that the Invoice entity is deferred.
- **AWS replaces GCP as the storage target** (D8). Nothing in the flow, the document entity or the key structure changes — that is what the relative-key rule bought. Jira 4.1-S4T3 names GCP explicitly and needs updating, and the audit sink was described as already on GCS, so either two clouds are in play or it migrates too.

4 The target flow

Two approval gates. A company is approved once. After that, every invoice it submits is approved separately. Each gate is decided by a single COMPLIANCE or ADMIN approver who records a rationale, through the case engine rather than a lifecycle click (D5).

Gate 1 — Company (once per exporter)

Step	What happens	State
1 Create	Operator creates the exporter. Contacts, activities and pipeline stages follow. Every stage change writes an append-only event.	Works
2 Documents	Company paperwork, uploaded by category (4.3). Scanned before it becomes viewable. Owner type EXPORTER.	Build
3 Checks	KYB (Middesk / Trulioo), identity (Sumsub), sanctions screening, risk rating. Manual entry remains available. Any check can be re-run.	Wire + Build
4 Review	Eight-item screening checklist with full change history, plus per-check accept / reject / escalate.	Works + Fix
5 Decision	An onboarding case. One COMPLIANCE or ADMIN user reviews the aggregated evidence, records a rationale and decides. The evidence list is snapshotted (D17).	Wire
6 Outcome	ONBOARDED → FINANCING_ELIGIBLE — cleared to submit invoices — → ACTIVE.	Works

Gate 2 — Invoice (repeats, many per exporter)

Step	What happens	State
1 Arrival	From an operator, from RXIL, or from the exporter. Source recorded on the invoice.	Build
2 Documents	Shipment and trade paperwork, by category (4.3). Owner type INVOICE.	Build
3 Checks	Duplication, vessel tracking, buyer rating, insurance. The check types already exist as enum values.	Build
4 RXIL evidence	Where RXIL supplied results, they are ingested as given and never recomputed. Provenance is recorded per result.	Build
5 Decision	A funding case. Same shape as Gate 1: one approver, recorded rationale, snapshotted evidence.	Build
6 Outcome	FUNDED or DECLINED, recorded per invoice. Can be reopened by one approver with a mandatory reason (D10).	Build

4.3 Documents — categories and placement

Documents are uploaded through the UI at both gates and are the raw material for manual review. Category is a grouping layer above document_type; it does not replace owner_type or source. Three fields do three separate jobs: **owner_type** decides where a document appears, **category** decides which tab, **document_type** decides the label.

Category	Gate	Typical contents
ENTITY_KYC	Company	Incorporation certificate, PAN, GSTIN, IEC registration, board resolution, UBO declaration, director ID
COMPLIANCE_SCREENING	Company	Sanctions, PEP and adverse-media evidence
COMPANY_MARKET_REVIEW	Company	Generated analysis. source = SYSTEM (D16)

Category	Gate	Typical contents
BANKING	Both	Company bank statements · per-invoice FIRC, e-BRC
INSURANCE	Both	Annual policy · per-shipment marine certificate
PRE_SHIPMENT	Invoice	Proforma invoice, purchase order, sales contract, letter of credit
SHIPPING	Invoice	Bill of lading or MLETR eBL, packing list, vessel tracking report
CUSTOMS_AND_REGULATORY	Invoice	Shipping bill, customs declaration, GST returns, tax residency certificate
BUYER	Invoice	Buyer rating report, buyer KYC
OTHER	Both	Catch-all. Its absence pushes people to file documents in the wrong category, which is worse

Never more than seven categories are visible at once, because the view is contextual (D14). Tax sits inside CUSTOMS_AND_REGULATORY — the name is deliberately explicit, since GST returns and residency certificates are regulatory but not customs.

One trap to avoid. The category list must have a server-side contract. If it lives only as a frontend array while the backend accepts any string, this reproduces A3.4 exactly — a mistyped value saves cleanly, never renders, and the count disagrees with the database.

What is deliberately not in the flow

- **Underwriting / the credit call.** Excluded everywhere in this codebase. RXIL pre-filters before handing off.
- **Exporter self-service.** The exporter does not log in. Everything is operator-driven. (An exporter-submitted invoice under D13 arrives through an operator or an ingestion path, not a login.)
- **The formal Temporal journey.** Descoped under D11.
- **Full re-KYC** as specified by Epic 4.2 — baseline snapshots, change detection, event-driven re-review. C4's re-verify action is the light version. The full epic remains separate.

5 Fix register — code that runs but should not

Every item below was verified in the code. These are not hypothetical.

A1 Security

#	Problem	Evidence	Fix
A1.1	Unauthenticated privilege escalation. The signup route has no auth dependency and accepts a caller-chosen role, written straight to the user row. Anyone with network access can self-issue ADMIN and then read the platform audit trail.	auth/schemas.py:8–12 auth/router.py:43–60	Remove role from the schema. Hard-code API_USER. Add extra="forbid" — the schema currently has no model_config, so a stale client would get a silent 201 rather than a 422.
A1.2	No role enforcement. Roughly 22 routes check only that the caller is logged in. A plain API_USER can set sanctions_check = PASSED by calling the API directly.	onboarding/api/router.py exporter_router.py helper at platform/auth/orization/services.py:12–33	require_role already exists and gates three routes. Apply it — do not write a second one. Declare 403 in each route's responses block or it never enters the OpenAPI schema.
A1.3	Free-text provider reaches importlib. The caller controls both a module path and an attribute name; the resolved attribute is then invoked.	workflow_dependencies.py:647–656 verification_service.py:148 same shape at kyb/domain/ports.py:49	Constrain provider to a Literal at the schema boundary and restrict registry resolution to an allowlisted module prefix. A test currently pins the fallback as intended — update it, do not delete it.
A1.4	reviewed_by is forgeable. The review route injects current_user and never reads it, taking the reviewer from the request body instead.	api/router.py:406–417 correct pattern at exporter_router.py:495	Take it from the session. Note this changes the stored value from a display name to a UUID — silent, no test will catch it.
A1.5	Raw PAN and GSTIN in API responses. Masking happens only in the browser.	exporter_response_schemas	Mask server-side. Ownership-scoped reveal is noted in section 11.

A2 Lost history

This codebase knows how to do append-only — twenty tables have BEFORE UPDATE OR DELETE triggers calling a shared prevent_mutation(). The two newest features are precisely the ones that skipped it.

#	Problem	Evidence	Fix
A2.1	The screening checklist overwrites itself. A unique constraint on (customer_id, item_key) means a repeat write clobbers status, comment, reviewer and timestamp. Marking an item PASSED erases that it was ever FAILED, and who failed it.	screening_review.py:19–23 screening_review_service.py:38–63	Append-only, or a companion history table, following the existing trigger pattern. The GET response contract must not change.
A2.2	Stage changes exist only in stdout. actor_id is accepted and never persisted. No history table exists.	exporter_profile_service.py:542–559	Write an onboarding_event row per transition. The service already holds the repository at line 134 and uses it once, at 262.

#	Problem	Evidence	Fix
A2.3	onboarding_event is unreachable . Append-only, trigger-enforced, and read by no route. The evidence-package view model is already built.	onboarding_0002:312–318 onboarding_query_service.py:135–148	Mount a customer-scoped route, gated. Its docstring defers access control to "one layer up" — that layer is now us.

A3 Correctness

#	Problem	Evidence
A3.1	Frontend build broken on main. <code>noUncheckedIndexedAccess</code> makes <code>matches[0]</code> possibly undefined against a <code> null</code> return type. <code>tsc</code> exits 2, so vite build never runs. Fix the narrowing — do not <code>assert</code> , <code>cast</code> , or relax the flag.	<code>PipelinePage.tsx:56</code> <code>tsconfig.app.json:20</code>
A3.2	A stub check can be permanently approved. The review control gates on <code>review_status</code> only, never on <code>status</code> . A <code>PENDING</code> stub whose payload reads "Provider integration not configured" can be <code>ACCEPTED</code> — and the immutability trigger then makes that permanent.	<code>VerificationSection.tsx:231</code>
A3.3	"Run available checks" creates rows terminal at PENDING. The manual adapter's status method raises, the rows carry no <code>provider_reference</code> , and no other write path to status exists. Hide or relabel before any demo.	<code>VerificationSection.tsx:363-385</code> <code>manual_entry_adapter.py:127-140</code>
A3.4	item_key is unvalidated. Any string persists. The UI iterates its own eight hardcoded keys, so an unknown key is fetched, ignored and invisible — while the counter reads 0/8 with eight decisions in the table.	<code>exporter_router.py:484</code> <code>VerificationSection.tsx:57-66, 145-162</code>
A3.5	Transition table duplicated. Hand-copied to the frontend. Verified identical today — 13 edges — so this is a hazard, not a live bug. Serve it from the API when convenient.	<code>exporter_profile_service.py:99-122</code> <code>constants.ts:88-102</code>
A3.6	Stale generated API types. Omit the screening-review and bank-activity routes. Regenerate last, after all backend changes merge.	<code>openapi.json</code> , <code>schema.ts</code>
A3.7	Type pairs are never cross-validated. Four names appear on both <code>VerificationType</code> and <code>VerificationEntityType</code> with different meanings, so <code>verification_type=VESSEL</code> with <code>entity_type=EXPORTER</code> is accepted.	<code>orchestration_enums.py:111-152</code>
A3.8	No CRITICAL risk level. <code>VerificationRiskLevel</code> has <code>LOW/MEDIUM/HIGH</code> ; <code>OnboardingRiskRating</code> has <code>CRITICAL</code> . A vendor "critical" has nowhere to go. The frontend chip styling also has no <code>CRITICAL</code> branch and would render it as neutral grey.	<code>orchestration_enums.py:170-181</code> <code>VerificationSection.tsx:88-93</code>
A3.9	Six check types can never be run. <code>STUB_RUN_TYPES</code> lists three; <code>COMPANY_CHECK_TYPES</code> lists ten. The tab displays the other six but nothing creates them.	<code>VerificationSection.tsx:34-47</code>
A3.10	Unsaved comments are discarded. The checklist card's React key includes the comment, so it remounts on every save.	<code>VerificationSection.tsx:154</code>

A4 Baseline and hygiene

#	Task	Note
A4.1	Establish the real test baseline against Postgres	Blocking. Everyone needs it to judge their own changes
A4.2	Relocate 21 DB-backed tests out of tests/unit/	<code>test_state_machine.py</code> . They fail on connect and mislead anyone who assumes <code>unit/</code> runs without infrastructure
A4.3	Build a test fixture that seeds a privileged user directly	Must land before A1.1. Six test files mint <code>COMPLIANCE</code> and <code>ADMIN</code> tokens via the signup route
A4.4	Delete the empty storage scaffold and empty adapters	Eleven zero-byte files. No ticket references the module path
A4.5	Correct the stale documents	See Appendix B

#	Task	Note
A4.6	Write the migration checklist where an author will see it	This repo has been bitten twice: an ALTER TYPE ... ADD VALUE inside autocommit_block() committed while its transaction rolled back, and revision ids must be 32 characters or fewer

6 Wiring register — finished code with no caller

Each item is an adapter in the onboarding module. No other module's files are edited (section 1.3). None of this is new logic.

#	What exists	The wiring	Size
B1	OnboardingQueryService — evidence package, statistics, time-in-state. Complete and tested.	Mount it, gated COMPLIANCE/ADMIN. Folds into A2.3.	Trivial
B2	document_requirements_service — required documents per profile.	Expose read-only.	Trivial
B3	ConfigDrivenRiskRater.	Add a RISK_RATING check type and wrap the rater as an adapter. First wiring task that works end to end with no external dependency.	Small
B4	kyb — Middesk (US) and Trulioo (international), with ports and a registry.	Wrap the KYBAdapter interface as a VerificationAdapter and register by name. Results land in the verification_result table the CRM already reads and reviews. Needs Vault credentials before it does anything real — build now, switch on later.	Small
B5	Sumsb identity adapter and webhook route.	Wrap as a verification adapter, behind its existing flag.	Small
B6	EventBus, build_envelope, OnboardingEventPublisher.	Publish from the CRM write paths, best-effort, preserving the existing swallow-on-failure contract. Must come before B7 — case creation rides this bus (D6).	Small
B7	cases — lifecycle, notes, resolution, evidence aggregation, SLA monitoring. The two-person rule is a configuration flag.	Create a case on entry to COMPLIANCE_REVIEW via the bus; a thin router for queue, detail and decide; link cases.customer_id to the exporter; snapshot evidence at proposal time (D17). Leave the two-person rule off (D5). The lifecycle transition to ONBOARDED now <i>follows</i> the case resolution rather than being the decision. Adds two frontend screens — a queue and a case detail with the decide action.	Large

Why this shape. A ticket that says "build a KYB adapter" stays satisfied by the adapter it built; we are only giving it a caller it never had. No ticket reopens, no acceptance criterion changes, and the coupling is removable in one place.

7 Build register — what does not exist

Smallest honest version, behind an interface, so the production version is a swap rather than a rewrite.

Company side

#	What	Minimal scope	Size
C1	Document storage	A storage interface (upload, download URL, delete) plus one local-disk implementation. Store only a relative object key — never a provider URL, bucket or scheme (D8). Key shape: {env}/{owner_type}/{owner_id}/{source}/{document_id}{ext}. Filename and MIME type stay as database metadata, never in the key.	Large
C2	Malware scan step	Upload lands at its key immediately; the row is created PENDING_SCAN and is not retrievable. Clean → AVAILABLE. Infected or failed → QUARANTINED / SCAN_FAILED, never served, and it raises an alert. The scan result is logged as its own append-only event.	Small
C3	Document entity	New table, separate from onboarding_document. Fields: owner_type (enum), owner_id, category (enum, ten values — 4.3), document_type (seeded config , not an enum — D15), source (RXIL / EXPORTER_UPLOAD / INTERNAL / SYSTEM — D16), file_name, mime_type, size_bytes, scan_status, uploaded_by, uploaded_at, and for generated documents the model and prompt version. owner_type must accept INVOICE from day one (D12) even though only EXPORTER is used at this stage. Validate category server-side.	Medium
C4	Re-verify a check	No schema change — nothing blocks a second verification_result of the same type. "Run available checks" currently filters to types with no existing result, which is why there is no way to re-run one today.	Small
C5	Reopen a decision	Reviews are immutable by database trigger, so this is a new row or a review-history table, never an edit. One COMPLIANCE or ADMIN user, with a mandatory reason (D10).	Small
C6	Sanctions / AML screening adapter	Takes a company name, returns matches from a local list. Registers like any other check. A real provider later is one adapter (D8's pattern).	Medium
C7	Admin seed command	Idempotent, reads env vars, creates the first ADMIN and one COMPLIANCE account (D3).	Small
C14	AWS S3 storage adapter	A second implementation of C1's interface. Object Lock in compliance mode for seven-year retention, SSE-KMS for encryption at rest, IAM roles for access. Local disk stays for development and CI (D8). Build this in Stage 4 immediately after C3 — wiring AWS early is what avoids last-minute upload failures.	Medium

Invoice side — added by D12

#	What	Minimal scope	Size
C8	Invoice entity	Linked to the exporter. Amount, currency, status, and a source field (operator / RXIL / exporter, per D13). This is the prerequisite for everything below — duplication checking in particular is impossible without an invoice history to compare against.	Medium
C9	Buyer	Fields on the invoice for now. Split into its own record when buyer rating actually lands. Flagged rather than assumed.	Small
C10	Invoice-owned documents	C3's owner_type set to INVOICE. Invoice, bill of lading, insurance certificate, vessel report.	Small

#	What	Minimal scope	Size
C11	Funding case type	A second case type alongside onboarding review, with its own evidence set and a filterable queue. Single approver (D5). Evidence is snapshotted at proposal time as a document_id list, with later additions flagged rather than silently included (D17).	Medium
C12	Invoice-level checks	Duplication, vessel, buyer rating, insurance. The check types and VerificationEntityType.INVOICE already exist as enum values — they simply point at nothing until C8 lands. MLETR e-bills of lading has no exact match; SHIPMENT is close but MLETR likely deserves its own value.	Medium
C13	RXIL ingestion	One endpoint accepting a package and fanning it out into individual verification results, using StubRxilAdapter's existing shape. The payload is a guess until their spec arrives, so it stays clearly marked provisional. Build after C8 — their package is invoice-shaped, so building first means building twice.	Medium

8 Build order

Each stage is a gate. Do not start the next until the previous is green against the baseline.

Stage	Goal	Contents
0	Know where we stand	A3.1 (build fix, alone and immediately) · A4.1 (baseline) · A4.2 · A4.6 · the role matrix sign-off
1	Make it safe	A4.3 (test fixture — first) → A1.1 → C7 (seed command) → A1.2 → A1.3 → A1.4 → A1.5 · A4.4 · A4.5
2	Make it honest	A2.1 · A2.2 · A2.3 + B1 · A3.4 · A3.7 · A3.8 · A3.2 · A3.3 · A3.9 · A3.10 · A3.5 · A3.6
3	Wire what exists	B2 → B3 → B4 → B5 → B6 → B7
4	Build the company side	C1 → C2 → C3 → C14 (AWS S3) → C4 → C5 → C6
5	Build the invoice layer	C8 → C9 → C10 → C11 → C12 → C13
6	Frontend catches up	Documents section · case queue, propose and decide · invoice list and detail · re-verify control · follow-ups page (EXP-F7) · regenerated types last

Ordering rules that bite

These are not preferences. Each one was derived from something in the code that will break if the order is reversed.

Rule	Because
A4.3 before A1.1 — test fixture before removing role from signup	Six test files obtain COMPLIANCE and ADMIN tokens by posting a role to the signup route. Reverse the order and the suite has no way to get a privileged token — and one audit test starts passing for the wrong reason
A1.3 before any of B3–B5 — harden the registry before wiring	Every wrapper registers an adapter by name. Wire first and the allowlist gets written twice
A4.1 before anything merges	Without a baseline there is no way to distinguish a regression from a pre-existing failure
A3.1 alone and immediately	The build fails on main, so no frontend work can meet a build-passing criterion
B6 before B7 — events before cases	Case creation rides the event bus (D6)
C1 before C2 and C3	Scanning and provenance need something to attach to
C1 and local disk before C14 — prove the flow before adding S3	Doing S3 first means debugging IAM and the flow at the same time. Wire AWS early in Stage 4, but not first
C8 before C13 — invoice entity before RXIL ingestion	Their package is invoice-shaped; building the endpoint first means building it twice
Frontend types regenerate last	Three backend streams change route signatures. Regenerating early produces types that are wrong again immediately
Migrations are a linear chain	Allocate numbers up front so two developers do not both create the same revision. Any ALTER TYPE ... ADD VALUE needs the checklist from A4.6

9 Go-live gates

None of these is optional. Nothing external touches the system until all four are satisfied.

Gate	Why
All of Stage 1 merged	Until A1.1 lands, anyone with network access can self-issue an ADMIN account. Until A1.2 lands, any authenticated caller can set a sanctions check to PASSED
A real malware scanner behind C2's step	D9 built the gate deliberately so that the scanner is a drop-in. A pass-through scanner in production is an open file-upload endpoint. GuardDuty Malware Protection for S3 may satisfy this natively — confirm before committing to self-hosted ClamAV
C14 deployed: S3 Object Lock and SSE-KMS verified	Local disk does not survive a container restart and has no retention lock. The requirement is seven-year retention for AML records, which Object Lock in compliance mode provides

Known gaps that are acceptable at go-live, if documented

- **Field-level encryption / KMS.** Three epics assert ciphertext acceptance criteria against a capability that exists nowhere on the platform. This is a platform gap, not ours to close, but it must be recorded rather than silently failed.
- **RXIL ingestion remains provisional** until their spec arrives.
- **Real screening and KYB providers** need credentials. The adapters will be in place; switching them on is configuration.

10 Ticket impact

No existing ticket's code changes. What changes is context, acceptance criteria that were never satisfiable, and a handful of dependencies that resolve or newly appear.

Tickets whose text needs updating

Ticket	Change	Why
ANER-4.1-S1T1	Remove the ciphertext acceptance criterion; correct the field list; note that migrations 0005 onward extend the schema	No KMS exists. document_reference is actually storage_path; kyb_result was renamed screening_result; edd_required and edd_reason were added
ANER-4.1-S1T4	Note that vendor resolution is by registered name only	A1.3 restricts the dotted-path fallback. Acceptance criteria are unaffected — they all resolve by name
ANER-4.1-S4T3	Replace GCP Cloud Storage with AWS S3; keep the seven-year retention and immutability requirements	D8 changes the provider because of corridor restrictions on GCP. Object Lock in compliance mode satisfies the retention clause the ticket already specifies
ANER-4.1-S7T1	Name require_role as the enforcement mechanism	Its criterion about restricting sensitive fields to the compliance role had no mechanism until A1.2
ANER-4.1-S7T2	Unblocked. Split the Epic 3.2 screening evidence criterion out	B1 mounts it. But screening_evidence is hardcoded None because Epic 3.2 is absent, so that criterion cannot pass yet
ANER-4.2-S1T2	Unblocked. Rewrite the linked issue against the delivered event	It anticipates raising an issue because Epic 4.1 has no completion call. A2.2 supplies one on the COMPLIANCE_REVIEW → ONBOARDED edge
ANER-4.2-S3T3	Newly blocked. Decide whether prohibited and CRITICAL are the same concept	4.2 uses low/medium/high/prohibited; 4.1 uses CRITICAL. Must be settled before 4.2-S1T1 writes its enum constraint
ANER-4.4-S4T2	Newly blocked, latent. Record that API_USER's onboarding permissions must be decided	4.4 authenticates by API key and scope; A1.2 gates by role. A gateway call has no user. Epic 4.4 is paused, so this is recorded rather than urgent
EXP-1	The 403 acceptance criterion becomes real; the get_current_active_user convention statement is superseded	The criterion was never satisfiable — the prescribed convention has no wrong-role concept
EXP-2	provider is now constrained; reviewed_by leaves the request body; the headline fidelity test asserts the display path	D4 and A1.4. The ticket's free-string rationale no longer holds
EXP-F9	Frontend no longer sets reviewed_by; add a result.status criterion	A1.4 and A3.2. Its argument against a provider dropdown also inverts once providers are enumerated
E9	Two of six "Added" bullets describe behaviour that was never enforced	The Compliance/Admin edit rule was client-side only, and stub checks were not in fact non-decisive

New tickets needed

Ticket	Why no existing ticket covers it
Platform field-level encryption / KMS	Three epics assert ciphertext criteria against a capability that exists nowhere. Until it lands none of them can close
First-ADMIN bootstrap (C7)	A1.1 removes the only path to an admin account. 4.1-S6T2 provisions a customer account_admin — a different population

Ticket	Why no existing ticket covers it
Test privileged-token fixture (A4.3)	Six test files depend on the signup route for privileged tokens. No ticket owns test infrastructure
Declare 403 in route responses blocks	Without it the new status never enters the OpenAPI schema, so no generated client learns it exists
Temporal: formally descope (D11)	Seven tickets assume a running worker. No ticket owns the decision
Invoice entity and funding case (C8, C11)	D12 reverses a deferral recorded in three documents. Nothing covers the invoice as a unit of decision

11 Open questions

None of these blocks Stages 0 to 4. Each is recorded so it is not rediscovered as a surprise.

Question	Blocks	What would settle it
Does an RXIL package cover one invoice or many?	C13	Their integration spec
Do RXIL documents arrive as files or as references?	C13, C10	Their integration spec
How is an RXIL record matched to an exporter?	C13	Their spec. GSTIN / PAN / IEC / CIN has been proposed but nothing is built
Does the audit sink stay on GCS, or move to AWS?	C14	Infrastructure. D8 moves object storage to AWS; the audit sink was described as already integrated with GCS. Either two clouds are in play deliberately, or it migrates
GuardDuty Malware Protection for S3, or self-hosted ClamAV?	C2	A spike against the S3 bucket once C14 exists. Both fit behind C2's async gate, so this is a cost and operations question
Should the two-person rule ever be switched on?	—	Compliance, later. D5 leaves it as a configuration flag precisely so this stays cheap to revisit — a value threshold on invoices would be the obvious first use
Is ownership-scoped reveal needed for PAN and GSTIN?	A1.5	relationship_manager_user_id exists but nothing sets it. The role half is implemented; the ownership half needs a product call
Is prohibited the same concept as CRITICAL?	ANER-4.2-S3T3	The compliance owner of Epic 4.2. It may be a business state rather than a risk band
Does MLETR deserve its own check type?	C12	SHIPMENT is close but MLETR is specific enough that it probably does
Who owns Epic 4.1 and can sign off D11?	—	If nobody is available, descope anyway and let them object

A Appendix A — Evidence index

Every file and line referenced in this document, for anyone who wants to verify a claim rather than take it on trust.

Location	What is there
auth/schemas.py:8-12	RegisterRequest exposes a caller-supplied role and has no model_config
auth/router.py:43-60	Signup route: no auth dependency; role written straight through
platform/authorization/services.py:12-33	require_role — exists and works. Used on three live routes only
audit/api/router.py:25, 44 · compliance/api/router.py:44, 72	The only three role-gated routes in the mounted API
workflow_dependencies.py:647-656	get_adapter: registry lookup, then importlib fallback with no allowlist
verification_service.py:147, 221, 290	The three call sites into get_adapter
verification_service.py:148	adapter_cls() — the resolved attribute is invoked
kyb/domain/ports.py:49	The same dotted-path fallback shape
api/router.py:406-417	Review route injects current_user and never reads it
exporter_router.py:495	The correct pattern — actor_id from current_user
screening_review.py:19-23	UniqueConstraint(customer_id, item_key)
screening_review_service.py:38-63	The upsert that clobbers prior decisions
exporter_profile_service.py:99-122	PERMITTED_LIFECYCLE_TRANSITIONS — 13 edges
exporter_profile_service.py:134, 262	OnboardingEventRepository held, and used once for lead creation
exporter_profile_service.py:542-559	transition_lifecycle_status — logger only
onboarding_0002:312-318	onboarding_event append-only trigger
onboarding_query_service.py:135-148	get_onboarding_evidence_package, and the docstring deferring access control
orchestration_enums.py:111-152	VerificationType (18 values) and VerificationEntityType (6)
orchestration_enums.py:170-181	VerificationRiskLevel — no CRITICAL
manual_entry_adapter.py:127-140	get_verification_status raises — stubs are terminal
PipelinePage.tsx:56 · tsconfig.app.json:20	The build break and the flag that causes it
VerificationSection.tsx:57-66	The eight hardcoded checklist keys
VerificationSection.tsx:231	Review controls gate on review_status only
VerificationSection.tsx:363-385	runAvailableChecks — creates terminal PENDING rows
bootstrap.py:334-349 · config.py:154	Temporal worker removed; TEMPORAL_ENABLED defaults False
app/platform/storage/	Eleven zero-byte files
cases/application/case_lifecycle_service.py:106-107	The compliance vs cases ComplianceCase naming collision, acknowledged in source

B Appendix B — Documents this one corrects

Each of the following is stale or wrong in a way that would mislead someone building from it. Correcting them is A4.5.

Document	The claim	Reality
README.md gap #6	No HTTP layer exists for either onboarding or cases	Half stale. Onboarding has two mounted routers. cases still has none
README.md, "recommended next step"	Build the internal API layer before frontend work starts	Frontend work has since shipped against the onboarding router
cases/README.md	Only S1T1 and S1T2 are implemented	Understates. Nine application modules exist — but none is reachable, which is the point worth making
Blueprint	Case review is "Live" and a case opens automatically	Neither is true. No router, and nothing creates a case outside tests. The most dangerous of these, because it tells a designer the capability exists
exporter-crm-frontend-tickets.md	The frontend is an empty skeleton; F4–F10 are not built	F1–F6 and F8–F10 are built. Only F7 is not
Implementation guide, RXIL section	INVOICE_DUPLICATION, VESSEL, BUYER and INSURANCE have no enum value	All four exist at <code>orchestration_enums.py:131–136</code> . The guide's own document-storage section contradicts its RXIL section
Blueprint, frontend ticket doc, README	The Invoice / FinancingOpportunity entity is deferred until underwriting	Superseded by D12. Funding is decided per invoice

If something in this document turns out to be wrong, correct it here rather than in a message. The value of this file is that it is the only place anyone has to look.

Appendix C — One-page overview

EXPORTER ONBOARDING & COMPLIANCE

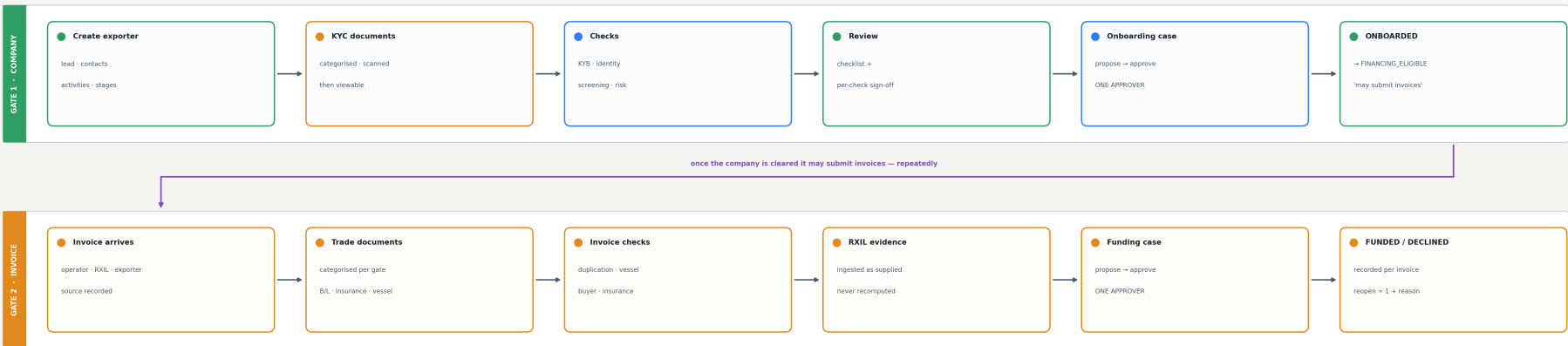
Developer mind map · two approval gates · build order · locked decisions

LEGEND

- works today
- FIX — broken or unsafe
- WIRE — built, no caller
- BUILD — does not exist
- decision / go-live gate

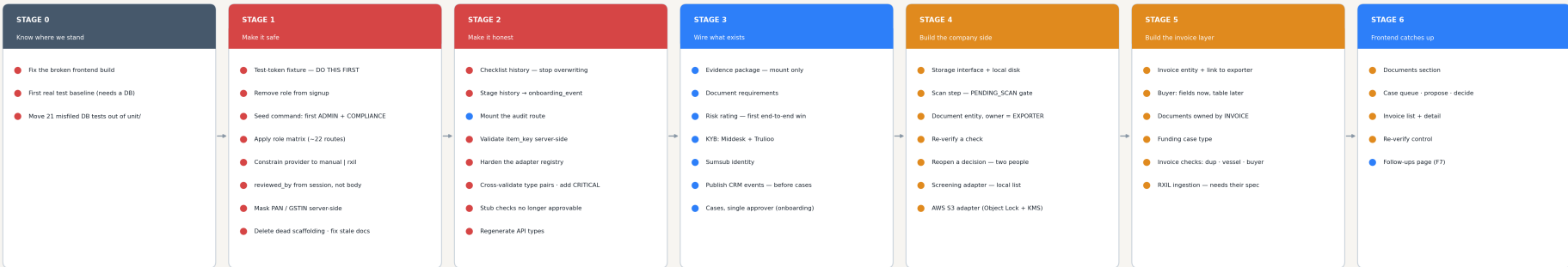
1 · THE FLOW

a company is approved once; then every invoice is approved separately — one approver at each gate, with a recorded rationale



2 · BUILD ORDER

each stage is a gate — do not start the next until the previous is green



DECISIONS LOCKED

Role matrix
Follow-ups
First ADMIN
Provider
Approvals
Case creation
Stage history
Storage
Reopen
Temporal
Funding
Documents

OPERATIONS+ writes - COMPLIANCE/ADMIN reviews - reads open to all team-wide — everyone sees all pending work
Idempotent seed command reading env vars
stored lowercase, displayed uppercase — no migration
case engine, SINGLE approver + rationale — both gates
via the existing in-memory event bus
onboarding_event — epic 4.2 reads from it
local disk now → AWS S3 - relative object keys only
one approver, mandatory reason, new record not an edit
FORMALLY DESCOPED — the CRM path is the onboarding flow
PER INVOICE — company gate first, then each invoice
10 categories, shown contextually per gate - type = seeded config

ORDERING RULES THAT BITE

- Test fixture BEFORE removing role from signup
else no test can obtain a COMPLIANCE token
- Harden the registry BEFORE any wiring
every wrapper registers an adapter by name
- Baseline BEFORE anything merges
else 'I broke it' is indistinguishable from 'I already did'
- Events BEFORE cases
case creation rides the in-memory bus
- Storage BEFORE scan step and document entity
scanning and provenance need something to attach to
- Invoice entity BEFORE RXIL ingestion
their package is invoice-shaped — else you build it twice

GO-LIVE GATES · STILL OPEN

- MUST LAND BEFORE EXTERNAL USE**
- Real malware scanner behind the C2 gate
 - S3 Object Lock + SSE-KMS verified
 - All of stage 1 merged
- STILL OPEN — not blocking**
- RXIL: one invoice per package, or many?
 - RXIL: documents as files or as links?
 - Audit sink: stay on GCS, or move to AWS?

Wiring rule: all glue lives in the onboarding module. No file in kyb / cases / customers / compliance is edited — their tickets stay finished, and the coupling can be removed in one place.